

GreenGrid Renewable Energy Management.

Information Security Management System (ISMS) Documentation

Project Scenario: Critical Infrastructure Protection (Pod Vega)

Name: Remi Adeparusi

Date: April 2026

Classification: CONFIDENTIAL — RESTRICTED

Standards: ISO/IEC 27001:2022 | IEC 62443 | NDPA 2023

ORGANIZATIONAL CONTEXT DOCUMENT (OCD-001)

ISO/IEC 27001:2022

Field	Details
Organization	GreenGrid Renewable Energy Management
Document Title	Organizational Context Document
Document ID	OCD-001
Version	1.0
Date	April, 2026
Document Owner	Chief Information Security Officer
Classification	Confidential
Review Cycle	Annual
ISO/IEC Reference	ISO/IEC 27001:2022, Clause 4

1. Purpose

The goal of this Information Security Management System (ISMS) is to develop a structured, risk-based approach to protect GreenGrid information assets and operational technology from cyber threats. This ISMS aims to ensure confidentiality, integrity, and availability of informational technology and operational technology systems, with a focus on protecting SCADA infrastructure that supports power generation and grid stability.

This document identifies the internal and external issues relevant to GreenGrid's Renewable Energy Management affects its ability to achieve the intended outcomes of its information security management systems (ISMS).

This ISMS seeks to balance security, operational efficiency, and business goals by ensuring that Cybersecurity measures are utilized in a manner that shows real-world risks, resource limits, and the critical nature of GreenGrid's services.

Understanding the Organization and Its Context

2. Organizational Description

GreenGrid Renewable Energy Management operates a network of solar and wind energy installations across West Africa, headquartered in Lagos, Nigeria, with operational sites across different parts of West Africa. GreenGrid has a combined installed capacity of 480 MW. Power is being sold from those sites to national grid operators through a Power Purchase Agreement. Besides that, their SCADA (Supervisory Control and Data Acquisition) systems monitor and control power generation remotely. They sell electricity to national grids and manage billing for commercial clients.

GreenGrid tech setup is broad. Information Technology (IT) comprises corporate systems, the customer portal, and billing. The Operation Technology side runs the SCADA, energy management systems, distributed control systems, and industrial IoT sensors, and every other thing needed for the smooth running of the generation sites. The convergence of OT and IT is creating new Cyberattack surfaces, thereby making this situation a major concern, and managing these risks is exactly what this ISMS aims to achieve.

3. External Issues

The following external issues have been identified:

Nigeria Data Protection Act 2023 (NDPA) and Nigeria Data Protection Regulation (NDPR): GreenGrid collects personal data from commercial and industrial clients, employees, and field engineers, including location data for teams working in the field.

Both NDPA 2023 and NDPR set out strict rules on data protection, and Greengrid has to adhere to these rules. Therefore, appointing a Data Protection Officer is required. National State Threat Actors: Energy infrastructure attracts a penalty of attention. It is a known target for nation-state hackers and advanced persistent threat groups. There have been several attacks on SCADA systems or power plants. For this reason, Greengrid needs to build nation-state threat modeling into its risk assessment.

IEC 62443 Industrial Control Systems Security: IEC 62443 sets the global standard for cybersecurity in industrial automation and control systems. Greengrid, being a SCADAdependent energy operator, is expected by investors and grid operators to align with IEC 62443 zones and conduit architecture.

Political and Legal Environment: Evolving cross-border power trading agreements, restrictions, and other bodies that impose operational and reliability standards on generation companies. Cyber legislation can impose regulatory penalties due to cybersecurity, causing generation failures.

Competitive and Investor Landscape: The renewable energy industry is booming, and the competition for funding is high. Investor development banks require ISO 27001 certification and CNI Cybersecurity standards compliance as part of their conditions.

4. Internal Issues

The following internal issues have been identified:

Security Culture and Awareness: Staff are more operationally focused, leading to minimal security training and awareness. There is no security program available to target the OT teams.

Geographical Dispersion: Assets are spread across different countries, and the quality of telecom infrastructure remains inconsistent. In some of these remote sites, the SCADA systems depend on 4G/LTE because of the lack of fiber.

Financial Profile: GreenGrid is still a growing company. It has a low percentage of IT spending, which doesn't match up with the high level of risk tied to critical infrastructure.

Information Technology (IT)/Operation Technology (OT): GreenGrid has been steadily linking its OT systems, such as SCADA and ISC, with the main IT networks so they can monitor everything remotely.

Existing Security Posture: The current setup covers some OT basics, such as firewall, antivirus, and an email gateway, but the OT part is lagging.

5. Needs and Expectations of Interested Parties

GreenGrid has identified the following interested parties and their expectations:

Interested Party	Need and Expectation	Relevance to ISMS
------------------	----------------------	-------------------

Clients	Clients expect a reliable power supply under SLA. They expect their billing and energy use data to be private. Outage alerts are expected to be sent on time.	Client data must be classified and guarded. SLA guarantees for power availability should be backed by ISMS controls.
Regulators	Demonstrated compliance with Nigeria Electricity Regulatory Commission (NERC), Ecowas Center for Renewable Energy and Energy Efficiency.	SCADA availability and integrity controls must align with all regulators grid code and there must be a timely report of power outage caused by cybersecurity.
Investors/ Shareholders	Risk mitigation, evidence of information security governance meeting international standards (ISO 27001) protection of their investment, protection of brand reputation and regulatory compliance.	ISO 27001 certification should support investors due diligence requirements.
Employees	Access to training, safe working environment and secure systems. Protection of employees personal data.	Employees' data must comply with NDPA.
Third Party Vendor	Compliance with vendor security requirements, regular management and update of software and firmware that align with vendor guidelines.	Vendor hardening guidelines should be implemented.

6. Monitor and Review

The organization's context is reviewed annually or upon significant business or regulatory changes. This ensures GreenGrid ISMS remains relevant and effective.

This document supports clauses 4.1 and 4.2 of ISO/IEC 27001:2022 and serves as the foundational input for the development of the ISMS risk assessment process and security objectives.

7. ISMS Scope Statement

GreenGrid Information Security Management Systems covers the IT and OT systems, such as the design, operations, monitoring, and security that support renewable energy generation across West Africa.

Included in the scopes are:

- All SCADA systems are involved in monitoring and controlling energy Infrastructure.

- Cloud-based platforms and other third-party vendors and data storage, processing, and analytics.
- Employees and contractors' personal data processed in connection with employment.
- Energy management systems and operational dashboard.
- Corporate IT systems such as client billing portal, corporate email, finance, and administrative platforms.
- Physical security of all sites. **Geographic Boundary:**

This ISMS involves all GreenGrid operations across all West Africa, including generation sites, offices, and remote working environments.

Organization Boundary:

The ISMS will apply to all field engineers, operational staff, and third-party vendors who have access to GreenGrid systems. Finally, all staff and contract employees.

Technology Boundary:

The ISMS will cover IT systems such as all applications, corporate networks, cloud infrastructure, billing portal, customer management systems. OT systems such as the SCADA system. The Communication network that connects IT and OT environments.

8. Exclusion (Things Outside the Scope)

Stated below are the following items excluded from the ISMS:

- National grid infrastructure that is managed and owned by external grid operators or providers.
- Personal devices that belong to C&I clients.
- Third party systems that have no direct operational control with GreenGrid.

9. Justification for Exclusion

These exclusions are justified because GreenGrid does not oversee the security of external systems. Although GreenGrid manages the risks related to these systems through contracts, third-party risk management processes, and service level agreements.

DELIVERABLE 2 — INFORMATION SECURITY POLICY

ISO/IEC 27001:2022 Reference: Clause 5.2 — Policy

Field	Details
Document Title	Information Security Policy
Version	1.0
Date	March 2026
Document Owner	Chief Information Security Officer (CISO)
Classification	CONFIDENTIAL — RESTRICTED
Organization	GreenGrid Energy Systems Ltd.
Review Cycle	Annual — or significant changes to OT/IT infrastructure
ISO/IEC Reference	ISO/IEC 27001:2022 IEC 62443 NDPR

1. Policy Overview

1.1 Purpose

This Information Security Policy (ISP) demonstrates how GreenGrid Energy Systems Ltd. will protect all information assets, operational technology systems, and critical infrastructure under its control by ensuring their security and availability. GreenGrid manages green energy assets that are designated Critical National Infrastructure (CNI) in various West African countries. If someone successfully hacks into GreenGrid's SCADA systems, the electricity may go out, field workers may be injured, national power grids may become unstable, and commercial clients may suffer significant financial losses.

1.2 Scope

This policy is applicable to all employees of GreenGrid, field engineers, contractors, OT vendors, and IT providers. It encompasses all information assets, operational technology systems, SCADA infrastructure, network equipment, endpoint devices, and physical facilities under the scope of the Information Security Management System as delineated in the Organizational Context Document.

1.3 Information Security Objectives

- Make sure that GreenGrid's SCADA systems and OT infrastructure are always available and safe, so that no cyberattack can cause a power loss or grid destabilization event.
- Put in place and keep up security controls that are in line with ISO/IEC 27001:2022 and IEC 62443, and that fulfil the needs of national regulators, grid operators, and institutional investors.
- Follow the Nigeria Data Protection Act 2023 (NDPA), the Nigeria Data Protection Regulation (NDPR), and any other data protection laws that apply in Ghana, Senegal, and Côte d'Ivoire to protect the personal information of workers, field engineers, and C&I clients.
- Get ISO/IEC 27001:2022 accreditation in 18 months to meet the needs of investors and help GreenGrid raise money for its Series D round.

1.4 Policy Statement

The Board of Directors at GreenGrid fully supports this policy and requires that all activities follow it to the letter. Information security problems at GreenGrid are not seen as technical issues because the company is a CNI. Instead, they are seen as critical threats to the company, the national grid, and the communities GreenGrid serves.

2. Information Security Governance — Roles and Responsibilities

Role	Information Security Responsibilities
Board of Directors	Accept the budget for the ISMS and OT security program; adopt the ISMS policy and risk appetite; obtain quarterly OT/IT security risk dashboards; and notify national regulators of significant occurrences.
Chief Executive Officer (CEO)	Promote a culture of cybersecurity throughout GreenGrid. Make sure that security duties are included in PPAs and commercial contracts and approve major security investment decisions.
Chief Information Security Officer (CISO)	Own and run the ISMS; oversee the IT and OT security program; chair the Information Security & OT Risk Committee; manage connections with CNI regulators; report to the Board on security posture.
OT Security Engineer	As a specialist in charge of SCADA/ICS security. Set up the IEC 62443 zone and conduit design, handle OT vulnerability assessments, and work with SCADA manufacturers like Siemens and ABB on security patches.
Head of Engineering / NOC Manager	Make sure that field engineers follow OT security rules, regulate who can get into generation sites, and impose security controls on industrial mobile devices and field laptops.
Data Protection Officer (DPO)	Ensure compliance with NDPA 2023 and NDPR for employee and C&I customer data; uphold ROPA; conduct DPIAs for new data processing activities.
IT Operations Manager	Manage corporate IT security rules; administer Active Directory and identity management; enforce endpoint security; and communicate with Microsoft Azure about cloud security posture.
All Employees and Field Engineers	Complete necessary security awareness training; follow all security policies; immediately report suspected security events; never connect unauthorized devices to OT networks.

3. Information Classification and Handling

GreenGrid classifies all information assets into four levels. OT-related data (SCADA configurations, network diagrams, PLC ladder logic) and CNI-sensitive information receive additional handling restrictions beyond the standard classification requirements.

Level	Description	OT/CNI Examples	IT Examples	Key Handling Requirements
RESTRICTED	Highest sensitivity.	SCADA network diagrams; PLC	PPA commercial	Need-to-know only; AES-256

	Exposure could cause physical	configurations; Grid connection	terms; Investor financial data;	encryption at rest; TLS 1.3 in transit;
	harm or national security consequences.	interface schematics; OT vulnerability assessments	Incident response playbooks	No cloud storage without CISO approval
CONFIDENTIAL	Sensitive business or operational data. Disclosure could cause significant commercial or reputational harm.	SCADA historian data. Maintenance schedules; OT asset inventory	C&I client billing data; Employee PII; Commercial contracts	Encryption in transit; Password protected sharing; Role-based access
INTERNAL	Internal operational information is not for public disclosure.	NOC operating procedures. IT/OT network change requests	Internal policies; Meeting minutes; Employee directory	No external sharing without approval. Standard access controls apply
PUBLIC	Approved for external release. No confidentiality expectation.	Annual sustainability Report: Press releases on new installations	Website content; Investor relations materials	Communications team approval is required before publication

4. Access Control

GreenGrid applies strict access control to both IT and OT environments, with separate access management regimes for each domain reflecting their different risk profiles and operational requirements.

4.1 IT Access Control

- All corporate IT user accounts are unique. Shared accounts are prohibited. Service accounts require documented justification and enhanced monitoring.
- Multi-Factor Authentication (MFA) is mandatory for all remote access, all admin accounts, and all accounts accessing the C&I billing portal and ERP system.
- Access rights are provisioned on a role-based, least privileged basis and reviewed quarterly for privileged accounts and annually for standard accounts.

4.2 OT Access Control — Additional Requirements

- Physical access to OT systems (SCADA workstations, engineering workstations, field RTU/PLC panels) is restricted to authorized OT personnel and documented in the OT Access Register.
- Remote access to OT systems is PROHIBITED for all external parties without CISO approval. When permitted, remote OT access must use a dedicated, isolated jump server with session recording, MFA, and time-limited access tokens.
- Vendor remote access to SCADA systems requires CISO pre-approval, is time-limited, fully monitored by NOC staff in real time, and revoked immediately upon completion.
- No IT domain accounts may be used to authenticate OT systems. Separate OT-specific credentials must be maintained for all OT access.

5. Asset Management

GreenGrid maintains separate IT and OT Asset Registers. The OT Asset Register is classified as RESTRICTED due to its value to threat actors conducting targeted attacks against GreenGrid's generation infrastructure.

- All IT and OT assets must be registered before deployment. Unregistered devices must not be connected to either IT or OT networks.
- The OT Asset Register must record asset type, manufacturer, model, firmware version, physical location, network address (if applicable), and patch status.
- All field engineer mobile devices and laptops must be corporate-issued, MDM-enrolled, and encrypted. Personal devices must never be connected to OT networks at generation sites.
- Portable media (USB drives) are PROHIBITED in OT environments. Exceptions require CISO written approval and use of dedicated, scanned, clean media only.

6. Physical and Environmental Security

Physical security of generation sites and NOC is a primary control layer for GreenGrid's OT security. Many OT attack vectors require physical proximity; physical security is therefore integral to OT cybersecurity.

- All generation sites are classified as security perimeters. Access is controlled by biometric or electronic access systems. All entries/exit events are logged.
- The NOC in Lagos is classified as a RESTRICTED zone. Access is limited to NOC operators, OT Security Engineer, Head of Engineering, and CISO.
- SCADA workstations and engineering workstations in the NOC must not be used for general internet browsing or email.

- Remote generation sites must be inspected for evidence of physical tampering with RTU/PLC panels as part of the monthly field engineer site visit programme.

7. Human Resource Security

The human aspect is a major attack vector in ICS/SCADA environments. APT organizations attacking energy infrastructure have documented the use of social engineering tactics on field engineers and NOC operators.

- Candidates with OT access must undergo rigorous background verification, including identity, job history, criminal record (where legally permissible), and financial checks.
- All NOC operators and field engineers must receive OT-specific security awareness training, covering social engineering detection, USB dangers, tailgating, secure remote access, and incident reporting.
- Annual information security awareness training is required for all staff. Phishing simulations are undertaken quarterly.
- Contractors with OT access must undergo a GreenGrid OT Security Induction before gaining site access.
- Leavers with OT access must revoke all access on their final day.

8. Cryptography

Cryptography is used throughout GreenGrid's IT system to ensure data confidentiality and integrity. In the OT context, where outdated protocols (Modbus, DNP3) lack native encryption, compensating measures are used.

- IT data in transit must use TLS 1.2 at a minimum. TLS 1.3 is required for all new integrations.
- Restricted and confidential data at rest must be encrypted with AES-256.
- SCADA communications across public networks (4G/LTE, satellite) using IPSec VPN tunnels and AES-256 encryption. Unencrypted SCADA traffic on any public network is forbidden.
- Documented key management procedures are required. SCADA VPN keys must be rotated annually. Compromised keys must be revoked and replaced within four hours.

9. Operations Security

Operational security processes ensure that GreenGrid's IT systems and OT infrastructure are handled securely, with a focus on the limits of OT environments where patching and change management must consider physical safety and generation continuity.

- IT Patch Management: Apply critical security patches to IT systems within 72 hours. High intensity patches within 14 days. All production changes require clearance from the Change Advisory Board (CAB).
- Extensive methodology for managing OT patches in 24/7 environments. All OT patches must be tested in a separate OT lab environment prior to deployment.
- For changes to SCADA setups, PLC ladder logic, or network architecture, a written OT Change Request must be approved by the OT Security Engineer and NOC Manager.
- Back up SCADA setups, PLC programs, and historian data regularly to an offline, air-gapped backup system. Backup integrity must be confirmed monthly.

10. Network and Communications Security

Network security is the major technical control domain for GreenGrid's IT/OT security initiative. The convergence of IT and OT networks is governed by using tight architectural constraints based on the Purdue Enterprise Reference Architecture and the IEC 62443 zones and conduit architecture.

- IT/OT Network Segmentation: Use an industrial DMZ to physically or logically segregate the OT network from the corporate IT network. Direct connection between IT and OT networks is banned.
- All remote SCADA connections (NOC to field stations) must use encrypted VPN tunnels. Primary communication via dedicated MPLS/fiber, where possible; backup via 4G/LTE VPN; and tertiary via satellite VPN.
- Deploy passive OT network monitoring products like Claroty, Dragos, or Nozomi Networks across all network segments. The NOC must monitor OT network alerts 24/7.
- Corporate IT Network: WAF was built to protect the C&I client portal and internetfacing services. Network access control (NAC) is enforced on the corporate LAN.

11. Incident Management

GreenGrid's incident management framework manages both IT and OT security incidents. OT security incidents have the potential to cause bodily harm and must be handled with extreme urgency.

- Immediately report any suspected security incidents to the CISO and NOC duty manager. For OT occurrences, reporting must occur within 15 minutes of discovery.
- GreenGrid categorizes incidents based on severity: P1 (Critical - immediate physical impact), P2 (High - verified OT/IT compromise), P3 (Medium - suspected compromise), and P4 (Low - small IT security event).

- In P1 occurrences, the NOC Manager initiates the Emergency Response Protocol. The CISO and CEO are notified within 30 minutes, and the Board within 2 hours.
- All P1 and P2 occurrences must be reviewed within 10 business days after the incident occurred.

12. Compliance, Audit, and Approval

GreenGrid adheres to all applicable legal, regulatory, and contractual information security standards throughout its four operating jurisdictions.

- Regularly examine the Regulatory Compliance Register for CNI cybersecurity regulations, data protection legislation, and grid code standards: Nigeria Cybercrimes Act 2015, NDPA 2023, NDPR, Ghana Cybersecurity Act 2020, NERC Grid Code, IEC 62443, and ISO 27001:2022.
- Annual ISMS internal audit conducted by qualified personnel outside of audited areas. OT security controls must be audited by ICS security experts.
- A CREST-accredited firm conducts annual external penetration testing on IT systems.
- The CISO conducts an annual ISMS Management Review to assess risk posture, KPI performance, and regulatory compliance status.

Policy Approved by:

Role	Name	Date	Signature
Chief Information Security Officer	Vega P	April 2026	
Chief Executive Officer	Lateef A	April 2026	
Board Chairperson	Stephen A	April 2026	

DELIVERABLE 5: VENDOR AND THIRD-PARTY RISK MANAGEMENT POLICY

Field	Details
Document Title	Vendor & Third-Party Risk Management Policy
Organization	GreenGrid Renewable Energy Management
Version	1.0
Effective Date	April 7, 2026
Approved By	Chief Information Security Officer (CISO)
Policy Owner	Risk & Compliance Department
Review Cycle	Annually
Classification	Internal Use Only

1. Field Details

See control page above for document details.

2. Objectives

The objective of this policy is to establish a comprehensive framework for identifying, assessing, managing, and monitoring risks associated with third-party vendors that support GreenGrid Renewable Energy Management's operations.

Given GreenGrid's reliance on renewable energy systems, smart grid technologies, cloud infrastructure, and IoT-enabled monitoring platforms, this policy ensures that all external partners maintain appropriate security, privacy, and operational resilience standards to protect critical energy infrastructure and sensitive data.

3. Scope

This policy applies to:

- All employees, contractors, and departments within GreenGrid Renewable Energy Management
- All third-party vendors, suppliers, and service providers engaged by GreenGrid
This includes vendors with access to:
 - Smart grid and energy distribution systems
 - Operational Technology (OT) and IoT monitoring devices
 - Customer energy usage and billing data
 - Cloud-hosted platforms and infrastructure
 - Internal IT systems, applications, and networks

4. Policy Statement

GreenGrid Renewable Energy Management requires that all third-party vendors undergo a formal risk assessment and ongoing monitoring process before and throughout their engagement.

No vendor shall be granted access to GreenGrid systems, data, or infrastructure without meeting the organization's defined security, compliance, and operational risk requirements.

5. Detailed Procedures

5.1 Vendor Risk Classification

All vendors shall be classified based on the level of risk they pose to GreenGrid's operations:

High-Risk Vendors:

- Access to smart grid systems or energy distribution infrastructure
- Access to real-time energy monitoring data or control systems
- Cloud service providers hosting critical applications
- Vendors supporting Operational Technology (OT) environments **Medium-Risk**

Vendors:

- Access to limited internal systems or non-sensitive operational data
- SaaS providers supporting business functions (e.g., HR, analytics tools) **Low-**

Risk Vendors:

- No access to internal systems or sensitive data
- Provide non-technical or indirect services (e.g., office supplies)

5.2 Vendor Due Diligence and Onboarding

Before boarding, all vendors must undergo a formal due diligence process that includes:

- Completion of a security risk assessment questionnaire aligned with industry standards (e.g., ISO 27001, NIST)
- Review of security certifications (e.g., SOC 2, ISO 27001) where applicable
- Evaluation of data protection and privacy practices, encryption and data transmission controls, incident detection and response capabilities, and regulatory compliance relevant to the energy sector

High-risk vendors must undergo enhanced due diligence, including technical security reviews and, where applicable, on-site or virtual audits.

5.3 Contractual Security Requirements

All third-party agreements must include the following security and compliance provisions:

- Data protection and confidentiality clauses
- Mandatory breach notification within 24 to 72 hours of detection
- Right-to-audit clause for GreenGrid
- Requirements to comply with GreenGrid security policies and standards
- Data residency and storage requirements where applicable
- Defined Service Level Agreements (SLAs) for availability and security

5.4 Access Control & Data Handling

- Vendor access must follow the principle of least privilege
- Access shall be granted only after formal approval and risk assessment
- Multi-factor authentication (MFA) must be enforced for system access

- Vendors must not store or process GreenGrid data outside approved environments
- All data transfers must be encrypted using approved security protocols

5.5 Ongoing Monitoring & Review

GreenGrid shall continuously monitor vendor performance and risk posture through:

- Annual risk reassessments (more frequent for high-risk vendors)
- Review of updated certifications and compliance reports
- Monitoring security incidents, SLA adherence, and changes in vendor ownership, structure, or operations

Automated monitoring tools may be used for critical vendors where applicable.

5.6 Incident Management

All vendors must:

- Immediately report any security incidents, breaches, or vulnerabilities impacting GreenGrid systems or data Upon notification, GreenGrid will:
 - Assess the potential impact on energy operations and infrastructure
 - Activate its internal incident response procedures
 - Coordinate with the vendor to contain, investigate, and remediate the issue

5.7 Vendor Offboarding

Upon termination of a vendor relationship:

- All system and physical access must be revoked immediately
- Vendor accounts must be disabled or removed
- All GreenGrid data must be securely returned or destroyed
- A formal offboarding review must confirm no residual access or data exposure

6. Roles and Responsibilities

Role	Responsibilities
Chief Information Security Officer (CISO)	Approves policy and oversees third-party risk management strategy
Risk & Compliance Team	Conducts vendor risk assessments and ongoing monitoring
IT Security Team	Evaluates technical security controls and manages access
Procurement Team	Ensures vendors meet policy requirements before onboarding

Business Unit Managers	Identify vendor needs and ensure adherence to policy
Legal Team	Reviews and enforces contractual security requirements
Vendors	Comply with all GreenGrid security, compliance, and contractual obligations

7. Policy Enforcement

Failure to comply with this policy may result in:

- Termination of vendor contracts
- Revocation of system access
- Disciplinary action for employees involved
- Legal action where applicable

8. Review & Maintenance

This policy shall be reviewed annually or upon significant changes to:

- Regulatory requirements
- Business operations
- Technology infrastructure
- Threat landscape

DELIVERABLE 6: PERFORMANCE MONITORING AND MEASUREMENT

Reference: ISO 27001 Clause 9.1 & GreenGrid Risk Register | Date: March 2026

1. Summary of Monitoring Goals

After reviewing the ISMS Documentation Package and the Risk Register, the performance metrics for Part 6 have been compiled.

The main goal here is to prove that the budget being spent is lowering our risks. Right now, the Dashboard shows that 33.3% of our risks are Critical, and nothing has been fully completed yet. These KPIs will give the Board a way to see that we are moving those risks from Critical to Low by the Q2 2026 deadline.

2. The KPI Tracking Table

The following 9 metrics are selected because they directly treat the risks identified in the Risk Register:

#	What We Are Measuring	Our Target	Why? (Risk Connection)
1	OT Network Visibility	100% Coverage	Stops hackers from moving between IT and OT (R-001).
2	Backup Success	100% Pass Rate	Protects against Ransomware risk (R004).
3	Patching Speed	72h (IT) / 30d (OT)	Fixes the old TLS/SCADA bugs in the register (R-002).
4	Staff Phishing Rate	< 8% fail rate	Direct defense against SpearPhishing (R007).
5	Physical Site Safety	100% monthly checks	Prevents physical intrusion at solar/wind farms (R-013).
6	Detection Time (MTTD)	Under 1 hour (P1)	Reduces Dwell Time for nation-state attackers (R-015).
7	Vendor Security	100% reviewed	Manages supply chain risks — Siemens/ABB (R-011).
8	MFA Adoption	100% on key systems	Protects HR and ERP data from stolen logins (R-009).
9	Legal Reporting	100% on time	Meets the 24-hour rule for the Nigeria Cybercrimes Act.

3. Analysis of Critical Risks (Linking Doc 1 and Doc 2)

Speed of Detection (KPI #6):

In the Excel Dashboard, SCADA cyberattacks are the #1 priority. According to industry info in the ISMS manual, hackers can stay hidden for over 200 days. By setting our Mean Time to Detect (MTTD) to under 1 hour, we are focusing on catching attackers before they can cause physical damage to the power grid.

Ransomware and Backups (KPI #2):

The Risk Register shows Ransomware (R-004) is an 'existential' threat with a score of 20. It's not enough to just 'have' backups. The KPI requires a monthly 'fire drill' restoration test. If we can't restore within our 4-hour target, we aren't protected.

The Human Factor (KPI #4):

Since our engineers are spread across Nigeria, Ghana, Senegal, and Côte d'Ivoire, they are prime targets for phishing. The target failure rate has been set at less than 8%. This is more important than just finishing a class — it measures if the engineers know how to spot a fake email in the field.

4. Conclusion

By tracking these monthly, we can show the CISO exactly where our security is weak. If these numbers stay green, we are meeting our ISO 27001 Clause 9.1 requirements and keeping the West African power grid stable.

DELIVERABLE 7: EXECUTIVE SUMMARY

For Presentation to the Board of Directors of GreenGrid Renewable Energy Management

GreenGrid operates vital renewable energy infrastructure across West Africa, providing electricity to the national grid and commercial clients. As a major service provider, it faces a growing threat from cyber-attacks that could disturb power generation, compromise sensitive operational data, and affect national stability.

The ISMS initiative has revealed several urgent risks that need immediate action. First, a potential breach of SCADA systems can create widespread power outages, impacting customers and national infrastructure. Secondly, ransomware attacks on operational and billing systems could stop energy production thereby leading to financial losses. Thirdly, insider threats, especially from field engineers with special access, could intentionally or accidentally disrupt energy systems.

If these risks are not properly managed, they could lead to service downtime, regulatory penalties, loss of stakeholders, and long-term business interruptions. Implementing an

ISMS aligned with ISO/IEC 27001 will give GreenGrid a well-structured way to manage information security risks.

The key benefits include improved operational resilience, Cyber insurance coverage and cost, strong regulatory compliance, better protection of critical infrastructure, and a solid reputation standing among clients, partners, stakeholders, and government.

It is recommended that GreenGrid move forward with the phased implementation of the ISMS over a 6–9-month period. The initial focus should be on securing high-risk systems like SCADA environments, enhancing access controls, and setting up incident response capabilities. The following phases should cover foundation and critical OT controls, ISMS implementation, certification audit, and continual improvement.

Finally, executive support and resource allocation will be crucial for the success of this initiative. With the right commitment, GreenGrid can significantly reduce its risk exposure while ensuring dependable and secure energy operations.

Student Names (All POD Members):	Adesuyi Oreofe, Olamide Akiode, Oluwamuyiwa Aikomo, Ologolo Halimat Damilola, Remi Adeparusi, Abdullah
POD Group Name:	Pod Vega
Organization Chosen:	GreenGrid Renewable Energy Management
Scenario Number (if applicable):	Scenario 5
Submission Date:	April 10 2026
Signature:	

